

Risk ID	Risk Description	Likelihood	Impact	Risk Rating
R-01	Unauthorised access to sensitive data due to weak authentication	Medium	High	High(RED)
R-02	Broken Access Control	Medium	Medium	Medium (Yellow)
R-03	Inactive or orphaned user accounts remaining active after employees leave	High	High	High(RED)
R-04	Security incidents go undetected due to poor or insufficient logging	Medium	High	High(RED)
R-05	Employees accidentally disclose sensitive information due to lack of training	High	High	High(RED)
R-06	Sensitive data is exposed because encryption is weak or not applied consistently	Low	High	Medium (Yellow)

Linked Control(s)	Mitigation
A8.5 Secure Authentication	Enforce MFA/passwordless, Apply conditional access Enable breached-password detection, Implement account lockout Use secure auth protocols (SAML/OAuth)
A5.15 Access Control	Apply RBAC, perform quarterly access reviews, enforce least privilege, and separate duties
A5.16 Identity Management	Provisioning & deprovisioning
A8.15 Logging	Apply log retention based on policy
A6.3 Information Security Awareness, Education and Training	Training regularly, also simulated phishing email and calls within the org
A8.24 Use of Cryptography	Using strong encryption methods

Status

In-progress

Open

Open

Mitigated

In-progress

Mitigated